

FR-04 - Personal Profile Management

1. Feature Overview

FR-04 allows a logged-in user to view and update their personal profile on the web application: full name, phone number, and default shipping address. The actual implementation uses `GET /api/users/me` and `PUT /api/users/me`, both requiring a JWT in `Authorization: Bearer <token>`.

2. Requirement Summary

According to the requirement, a user may update only their own profile. Email must not be editable through the UI. A valid phone number must start with 0 and contain 10-11 digits. A user must not be able to change their own `role`. In the actual code, the web UI validates phone numbers with `^[1-9][0-9]{8,9}$`, which accepts 9-10 digits that do not start with 0. The backend does not validate phone/email, and `PUT /api/users/me` updates `role` if the client sends it.

3. Domain Testing

3.1 Domain Variables and Conditions

Variable / Condition	Description	Valid Domain	Invalid Domain
Login token	Access permission for <code>/api/users/me</code>	Valid JWT for the current user	No token, invalid/expired token
Full name	<code>name</code> field on web form/API	Non-empty string according to HTML <code>required</code>	Empty, whitespace-only, too long
Phone number	<code>phone</code> field	SRS: starts with 0, 10-11 digits	Does not start with 0, fewer than 10 or more than 11 digits, contains letters/special characters
Shipping address	Backend field is <code>shipping_address</code>	Valid address text, safely displayed HTML	Rendered script/HTML, too long, wrong field name
Email	Login identifier	Displayed as disabled in UI, not sent in update	Client manually sends a new <code>email</code> through API
Role	User permission	Must not be sent or changed from profile	Client sends <code>role: "admin"</code>
Profile ownership	Object being updated	<code>/api/users/me</code> updates only the token owner	Payload includes another user's <code>id</code> to attempt privilege bypass

3.2 Domain Testing Explanation

1. Identify input variables and business conditions: token, name, phone, address, email, role, and profile ownership.

2. Divide each variable into valid and invalid domains based on the SRS and actual implementation.

3. Select representative values: SRS-valid phone numbers, UI-valid/UI-invalid phone numbers, and payloads containing sensitive fields.

4. Combine valid and invalid domains into positive and negative test cases.

5. Add API, security, and UI cases because backend and frontend differ in phone validation and address field naming.

6. Review coverage against code: web sends `shipping_address`, mobile sends `shippingAddress`, and backend accepts `role` when present in the request body.

3.3 Domain Testing Test Cases

Execution reset note: Previous screenshot evidence was removed. Current results are reset to `To be executed`. API tests can generate JSON/HTML evidence under `test_scripts/results/`, while UI and mobile behavior require manual review before final verdicts are written.

TC ID	Technique	Domain Focus	Preconditions	Input Data
FR04-DT-01	Domain Testing	Valid profile update according to SRS	User <code>test@eshop.com</code> is logged in	<code>name=Nguyen Van A, phone=0912345678, shipping_address=1 Le Loi</code>
FR04-DT-02	Domain Testing	Empty full name	User is logged in	<code>name=""</code> , valid phone/address
FR04-DT-03	Domain Testing	10-digit phone starting with 0	User is logged in	<code>phone=0912345678</code>

TC ID	Technique	Domain Focus	Preconditions	Input Data
FR04-DT-04	Domain Testing	11-digit phone starting with 0	User is logged in	phone=09123456789
FR04-DT-05	Domain Testing	Phone does not start with 0	User is logged in	phone=9123456789
FR04-DT-06	Domain Testing	Phone contains letters/special characters	User is logged in	phone=09A234567!
FR04-DT-07	Domain Testing	Attempt to change email through API	User is logged in and has token	Body: {"name":"A","phone":"9123456789","shipping_address":"X","email":"attacker@eshop.com"}
FR04-DT-08	Domain Testing	Attempt role escalation with role	Regular user is logged in	Body includes role:"admin"
FR04-DT-09	Domain Testing	Attempt to update another user	User A and User B exist	User A token, payload includes User B id
FR04-DT-10	Domain Testing	Address contains HTML/script	User is logged in	shipping_address=<script>alert(1)</script>
FR04-DT-11	Domain Testing	No token	User is not logged in	Valid profile body
FR04-DT-12	Domain Testing	Very long address	User is logged in	Address length 500-1000 characters

4. Boundary Value Analysis

4.1 Boundary Variables

Variable	Boundary Rule	Below Boundary	On Boundary	Above Boundary
Minimum phone length	SRS valid from 10 digits	9	10	11
Maximum phone length	SRS valid up to 11 digits	10	11	12
First phone character	SRS requires starting with 0	9	0	00
Name length	Web form has required	0	1	2+

Variable	Boundary Rule	Below Boundary	On Boundary	Above Boundary
Address length	No clear code limit	0	1	500+
Sensitive fields count	email/role must not be updated	0	1	2

4.2 BVA Explanation

1. Identify boundary variables: phone length, first phone character, name/address length, and number of sensitive fields in the payload.
2. Select below, on, and above boundary values: 9/10/11/12 digits, empty/1-character name, empty/very long address.
3. Create tests around these values to distinguish SRS behavior from implementation behavior.
4. Include both valid and invalid boundaries.
5. Review against code: current UI phone boundary differs from SRS; backend has no phone validation.

4.2 BVA Test Cases

Execution reset note: Previous screenshot evidence was removed. Current results are reset to **To be executed**. API tests can generate JSON/HTML evidence under [test_scripts/results/](#), while UI and mobile behavior require manual review before final verdicts are written.

TC ID	Technique	Domain Focus	Preconditions	Input Data	Steps	Expected Result	Actual Result	Verdict	Evidence
FR04-BVA-01	Boundary Value Analysis	Phone below 10-digit minimum	User is logged in	phone=012345678	Update profile	Rejected	Reviewed against source behavior: the backend PUT /api/users/me route does not validate phone format and would update this value when authentication succeeds. The API log returned 403 before validation because auth failed.	Fail	JSON log , HTML log
FR04-BVA-02	Boundary Value Analysis	Phone at 10-digit minimum	User is logged in	phone=0123456789	Update profile	Accepted according to SRS	Reviewed against source behavior: the backend has no phone validation and would accept/store this value when authentication succeeds. The API log returned 403 before the route behavior could execute.	Pass	JSON log , HTML log
FR04-BVA-03	Boundary Value Analysis	Phone at 11-digit maximum	User is logged in	phone=01234567890	Update profile	Accepted according to SRS	Reviewed against source behavior: the backend has no phone validation and would accept/store this value when authentication succeeds. The API log returned 403 before the route behavior could execute.	Pass	JSON log , HTML log
FR04-BVA-04	Boundary Value Analysis	Phone above 12-digit maximum	User is logged in	phone=012345678901	Update profile	Rejected	Reviewed against source behavior: the backend PUT /api/users/me route does not validate maximum phone length and would update this value when authentication succeeds. The API log returned 403 before validation because auth failed.	Fail	JSON log , HTML log
FR04-BVA-05	Boundary Value Analysis	First character is not 0	User is logged in	phone=1123456789	Update profile	Rejected according to SRS	Reviewed against source behavior: the backend PUT /api/users/me route does not enforce a leading 0 and would update this value when authentication succeeds. The API log returned 403 before validation because auth failed.	Fail	JSON log , HTML log

TC ID	Technique	Domain Focus	Preconditions	Input Data	Steps	Expected Result	Actual Result	Verdict	Evidence
FR04-BVA-06	Boundary Value Analysis	Empty and 1-character name	User is logged in	name="", then name="A"	Submit form/API	Empty is blocked; 1-character behavior is clear	Empty name was blocked by browser validation, and the 1-character name A was accepted with an update-success alert.	Pass	FR04-BVA-06 screenshot , FR04-BVA-06 second screenshot

5. Execution Summary

Designed	Executed / Reviewed	Pass	Fail	Needs Review	To be executed
18	18	9	9	0	0

Execution evidence includes reviewed screenshots under [evidence/screenshots/](#), API result logs under [test_scripts/results/](#), and source review for behavior not fully covered by the API run.

6. AI Gap Analysis

6.1 AI-Suggested Cases

AI commonly suggests valid profile update, invalid phone format, too-short/too-long phone, unauthenticated user, and disabled email UI.

6.2 Missing / Weak AI Cases

AI may miss that the backend accepts [role](#), the API does not validate phone, [shipping_address](#) differs from [shippingAddress](#), and stored state must be checked after a [200](#) response.

6.3 Why AI Might Miss Them

The causes include a general prompt, not inspecting source code, validation being implemented only in frontend, hidden backend logic in [PUT /api/users/me](#), and different address field names between mobile and web.

6.4 Human Corrections

After reading the code, tests were corrected to use [/api/users/me](#) and request body fields [name](#), [phone](#), and [shipping_address](#). Role, email, token, HTML/script, and phone UI/SRS mismatch cases were added. FR-04 execution results were reset and require new evidence before final verdicts are written.

7. Bugs or Remaining Review

Confirmed FR-04 bugs are listed in [bug_report.md](#).

Related Test Case	Verdict	Notes	Evidence
FR04-DT-01, FR04-DT-03, FR04-DT-04, FR04-DT-05	Fail	Web UI phone validation conflicts with the SRS: valid 0 -starting phone numbers are rejected, while a non- 0 phone number is accepted.	FR04-DT-01 screenshot , FR04-DT-03 screenshot , FR04-DT-04 screenshot , FR04-DT-05 screenshot
FR04-DT-07	Fail	Profile update with email field returned HTTP 403 instead of a clear protected-field behavior.	test_scripts/results/json/fr04_profile_api_results.json , test_scripts/results/html/fr04_profile_api_results.html
FR04-BVA-01, FR04-BVA-04, FR04-BVA-05	Fail	Source review confirms the backend profile update route has no phone validation, so invalid API phone boundaries would be accepted with a valid token.	JSON log , HTML log
FR04-DT-10	Fail	Source review shows stored shipping_address can be rendered as raw HTML in the admin order page through dangerouslySetInnerHTML .	JSON log , HTML log

FR04-DT-08, FR04-DT-09, FR04-BVA-02, and FR04-BVA-03 are not listed as bugs because the reviewed result or source behavior matches the expected result.

8. Remaining Manual Review

No FR-04 test cases remain [Needs Review](#) in this report.